

Technické mezery a rizika

Stav zdrojového kódu · commit 865549b026b02602d11648a3a7e9a12aa2878198 (fix/audit-findings-2026-09-22, 23. 9. 2026)

Slovník: úklidník = „Zhotovitel“ (VOP, RS, RŘ, Kodex) = Employee (kód) = „uklízeč“ (UI); zákazník = „Zákazník / Spotřebitel / Uživatel“ = User ; host = zákazník bez účtu (Order.UserId = null); provozní společnost = „Provozovatel / Cleansia s.r.o.“ = Tenant ; administrátor = Administrator / Manager / Support / Accountant .

Závažnost: **kritická** = ztráta peněz, porušení právní povinnosti nebo únik údajů jiné osoby možné dnes; **vysoká** = totéž v reálném scénáři vyžadujícím rozhodnutí; **střední** = chybné chování, malá oprava; **nízká** = hygiena, mrtvý kód.

Deset mezer

#	mezera	proč	závažnost	citace	→ Rn
1	Fiskální položky vynechávají doplňky, slevy a expresní příplatek	fiskální součet nemusí odpovídat platbě	vysoká	ReceiptService.cs: 368	→ R1
2	Administrátorské dokončení nespouští výpočet odměny	úklidník bez výplatního řádku	vysoká	AdminOverrideOrderStatus.cs:143	→ R6
3	Chargeback hledá objednávku jen podle PaymentIntent	webový Checkout může zůstat bez sporu	vysoká	HandlePaymentNotification.cs:463	→ R18
4	Refundace nemá dobropis	účetní návaznost mimo aplikaci	vysoká	Refund.cs:18	→ R1
5	Právní seed obsahuje neschválené návrhy	souhlasy nad návrhem	vysoká	cs.md:5	→ R3
6	Administrátor přiděluje bez kontroly schválení úklidníka	neověřený člen posádky	vysoká	AdminReassignOrder.cs:74	→ R11
7	Provozní společnost nemá aplikační založení	registr vzniká mimo administraci	vysoká	Tenant.cs:68	→ R2
8	Administrátor nemá druhý faktor	heslo chrání celý operátorský účet	vysoká	User.cs:14	2FA administrátora

#	mezera	proč	závažnost	citace	→ Rn
9	Cookie lišta mění obecné a e-mailové souhlasy	klik má širší účinek než cookies	vysoká	consent-sync.service.ts:39	→ R9
10	Hotovost nemá inkaso storna ani položku vedle BasePay ve výplatě	vybranou tržbu drží úklidník	vysoká	OrderEmployeePay.cs:38	→ R6

1. Bezpečnost

pravidlo	jedna věta	citace
S1 UserId is server-truth	Identita se čte z JWT claimu <code>NameIdentifier</code> , nikdy z těla; anonymní zápis jmenuje trh, server mapuje přes <code>SetTenantOverride</code>	UserSessionProvider.cs:29-32; OperatorTenantScopeBehavior.cs:53-69
S2 Authorization on every endpoint	Výchozí politika <code>RequireAuthenticatedUser</code> na všech pěti hostech; test odmítne admin akci bez <code>[Permission]</code> mimo <code>AllowList</code>	ServiceExtensions.cs:44-47; AdminHostPermissionCoverageTests.cs:62-66
S3 Resource-by-id ownership	<code>CanAccessOrderAsync</code> vrací true jen vlastníkov, přiřazenému úklidníkovi nebo administrátorovi; zákazník čte přes <code>GetQueryableForOwner(userId)</code>	OrderAccessService.cs:64-95; OrderAccessService.cs:38-44
S4 DTO leak prevention	<code>OrderPiiRedaction.RedactForBrowsingCleaner</code> nuluje jméno, e-mail, telefon, adresu a instrukce pro prohlížejího úklidníka; test drží seznam <code>DetailBlanked</code>	OrderPiiRedaction.cs:40-67; OrderRedactionSurfaceTests.cs:34-42
S5 Rate limiting	Politiky <code>auth</code> anonymně 10/min/IP, přihlášeně 30/min, <code>interactive</code> 60/min, <code>webhook</code> 60/min, strop 20 000 anonymních/min; <code>KnownUncovered</code> prázdný	RateLimitPolicies.cs:43-51; RateLimitCoverageGuardTests.cs:142-144
S6 Logging hygiene	<code>SafeBody</code> rediguje <code>SensitiveFieldRegex</code> a <code>ContactIdentityFieldRegex</code> ; cesty z <code>IsSensitivePath</code> potlačeny celé; test padne na neredigovaném DTO	RequestLoggingMiddleware.cs:197-210; RequestLogPiiSurfaceGuardTests.cs:98-103
S7 Idempotency	Webhook Stripe: <code>HasProcessedAsync(stripeEvent.Id)</code> před účinky; refundace drží unikátní <code>RefundKey</code> , kolize 23505 = existující řádek	HandlePaymentNotification.cs:158-173; RefundService.cs:97-118

pravidlo	jedna věta	citace
S8 Tenant isolation	Globální EF filtr (<code>SetQueryFilter</code>) e. <code>TenantId == currentTenantId</code> ; <code>CommitAsync</code> razítkuje <code>TenantId</code> a odmítne zápis do zmražené společnosti	<code>CleansiaDbContext.cs:307-328</code> ; <code>CleansiaDbContext.cs:103-116</code>
S9 Migration & DTO-contract safety	Jediná migrace <code>Initial</code> ; test drží 49 razítkovaných tabulek (<code>StampedTables</code>) s FK <code>_Tenants_TenantId</code> a NOT NULL mimo dvě obálkové (<code>EnvelopeTables</code>); <code>TenantId</code> je cizí klíč do <code>Tenants</code>	<code>InitialMigrationTenantDdlTests.cs:24-25</code> ; <code>TenantIdRequiredModelTests.cs:15-16</code>
S10 Soft-delete / IsActive	Bez globálního filtru; čtenář filtruje sám, např. <code>Where(s => s.IsActive)</code> u uložených adres	<code>SavedAddressRepository.cs:18</code>
S11 Mobile session wipe	Android <code>clearSessionCaches()</code> při vynuceném 401; iOS <code>SessionScopedCacheRegistry.clearAll()</code> při odhlášení i zamítnutém refreshi	<code>AuthAuthenticator.kt:116-119</code> ; <code>SessionScopedCache.swift:19-31</code>
S12 Stored artifact disclosure	Roster <code>ExpectedIntakes</code> 17 upload tras, 15 z nich s pravidlem obsahu (dvě <code>BlobFileSize</code> only); <code>ImageMetadata.Scrub(byte[])</code> vybírá walker podle bytů, nic nedekóduje	<code>UploadIntakeRosterTests.cs:39-60</code> ; <code>ImageMetadata.cs:35-57</code>

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Administrátorské přeražení načte cílového úklidníka podle id a ověří jen <code>EmployeeNotFound</code> a <code>EmployeeAlreadyAssignedToOrder</code> ; schválení (<code>EmployeeNotApproved</code>), které vyžaduje převzetí, ani měnu úklidníka nečte	<code>AdminReassignOrder.cs:74-87</code> ; <code>TakeOrder.cs:80-85</code>	zákazník / společnost	vysoká	kontrola schválení při přeražení
Administrátor bez druhého faktoru: jen heslo, limit 10/min/IP, lockout 5×/15 min	<code>rg -n "TwoFactor Totp Mfa"</code> <code>src/ → 0</code> ; <code>User.cs:14-17</code>	společnost	vysoká	2FA administrátora

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Zákaznický a partnerský web neinstalují AddUserRevocationEnforcement ani AddDeviceRevocationEnforcement ; jejich přístupový token 1440 min platí i po resetu hesla	UserRevocationServiceExtensions.cs:13-21; appsettings.Production.json:20	zákazník / úklidník	střední	revokace na webových hostech
Deaktivace odmítá přihlášení i refresh úklidníka; již vydané přístupové JWT nemají kontrolu společnosti při každém požadavku	RefreshToken.cs:102; CompanySignInGate.cs:27	společnost	střední	kontrola společnosti na přístupovém tokenu
Přiřazený úklidník čte adresu a instrukce i po dokončení; první čtení neprázdných instrukcí se audituje, přístup časově neomezuje	OrderAccessService.cs:94; GetOrderDetails.cs:163	zákazník	střední	→ R8
Registrace (ExistingUserWithEmail) i reset hesla (NotExistingUserWithEmail) prozrazují existenci e-mailu anonymnímu volajícímu	Register.cs:42-44; RequestPasswordChange.cs:46-48	zákazník	nízká	neutrální odpověď
DEV nasazení Logging__LogLevel__Console=Information ; RequestLoggingMiddleware pod ní spadá, těla požadavků jdou do App Insights	main.bicep:541; RequestLoggingMiddleware.cs:7-9	všichni (DEV)	nízká	úroveň Warning i v DEV
Mapbox veřejný token pk.eyJ ve 4 commitech historie; ve stromu jen placeholder runbooku	git log -S "pk.eyJ" --oneline → 4; AZURE-DEV-RUNBOOK.md:324	společnost	nízká	rotace tokenu

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Heslo lokálního Postgresu (Host=localhost) v trackovaném local.settings.json	local.settings.json:27	společnost	nízká	user secrets místo souboru
Nenasazená konfigurace PRO má zapnutý veřejný endpoint (publicNetworkAccess) a v prod parametrech zakomentovaný privateNetworkingEnabled; pravidlo AllowAllAzureServicesAndResources (0.0.0.0) je přepínač provozu uvnitř Azure	postgres.bicep:144-151; weu.prod.bicepparam:64-68	společnost	střední	privátní síť
Konfigurace připojení používá administrátor serveru cleansia_admin s Trust Server Certificate=true	derivedSecrets.bicep:48; weu.prod.bicepparam:74	společnost	střední	aplikační role; ověření certifikátu
CI neprovádí audit zranitelností; dva npm manifesty mají security-updates skupiny, měsíční plán a open-pull-requests-limit: 0 pro verzovací PR	dependabot.yml:30; dependabot.yml:46	společnost	střední	audit závislostí v CI
API hosty ani zákaznický SSR nenastavují HSTS ani CSP; partnerský a admin SWA nesou globalHeaders X-Content-Type-Options, X-Frame-Options, Referrer-Policy	rg -n "UseHsts Content-Security-Policy helmet" src --glob ".cs" --glob ".ts" → 0; staticwebapp.config.js on:12-15	všichni	nízká	bezpečnostní hlavičky
Fotky interiéru se vydávají SAS odkazem (GenerateSasUri) s platností 1 h — přeposlatelný nositelský odkaz	GetOrderPhotos.cs:117	zákazník	nízká	→ R7

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Bez virového skenu nahraných souborů; jen magic-byte <code>AcceptedByIntake</code>	<code>rg -in "clamav antivirus malware" src --glob "*.cs" → 0; SniffedContentType.cs:70-87</code>	společnost	nízká	AV sken uploadů
159 tenant-ignorujících výskytů, z toho 111 v repozitářích, bez samostatného rosteru; každý vyžaduje doložení vlastnického omezení	<code>rg pro IgnoreQueryFilters() / GetQueryableIgnoringTenant() v Database, AppServices, Functions a Functions.Core; OrderRepository.cs:248</code>	společnost	střední	roster výjimek tenantového filtru
Hesla s 10 000 iteracemi (LegacyIterations) jsou platná vedle 600 000; povýšení umí jen <code>NeedsRehash</code> , které nikdo nevolá	<code>rg -n "NeedsRehash" src --glob "*.cs" → 1 deklarace + 1 test; PasswordExtensions.cs:9-14</code>	zákazník / úklidník	nízká	povýšení hashe při přihlášení

2. Peníze a účetnictví

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Fiskální položky (<code>BuildFiscalLineItems</code>) jen služby a balíčky — bez extras, slev a příplatku; účinek je latentní, dokud je fiskalizace vypnutá	<code>ReceiptService.cs:368-392</code>	společnost	vysoká	fiskální položky = řádky dokladu
Bez dobropisu při refundaci; refund je jen řádek <code>Refund</code> a stav objednávky	<code>rg -in "creditnote credit_note dobropis" src --glob "*.cs" → 0; Refund.cs:81</code>	zákazník / společnost	vysoká	→ R1

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Číslo účtenky <code>RCP-{rok}-{NNNN}</code> (<code>ReceiptNumberFormat</code>); při <code>FiscalEnforcementMode.None</code> vrací <code>FiscalSequenceScope.NoAnnualResetYear</code> — pořadí pokračuje přes roky	<code>ReceiptService.cs:62-66;</code> <code>FiscalSequenceScope.cs:22-27</code>	společnost	střední	roční reset číselné řady
Administrátorský přepis na <code>Completed</code> neposílá <code>CalculateOrderPaymentMessage</code> — úklidník bez odměny	<code>rg -n "CalculateOrderPaymentMessage(" src/ → jen CompleteOrder.cs:347;</code> <code>AdminOverrideOrderStatus.cs:141-147</code>	úklidník	vysoká	výpočet odměny i z override
Vratka s <code>IsFailure</code> vrací chybu a spor neuzavírá; při úspěchu <code>Resolve</code> ukládá požadovaný refund, který se může lišit od skutečného	<code>ResolveDispute.cs:94;</code> <code>ResolveDispute.cs:102</code>	zákazník	střední	→ R10
Hostův <code>Dispute.UserId</code> je volitelný; chargeback webového Checkout nemusí najít objednávku, protože hledá jen <code>PaymentIntent</code> ; web ukládá <code>AssignStripeSessionId</code>	<code>HandlePaymentNotification.cs:463;</code> <code>OrderPaymentDispatcher.cs:66</code>	společnost	vysoká	→ R18
Prohraný chargeback jen zavře spor (<code>DisputeStatus.Closed</code>); <code>PaymentStatusPaid</code> se nemění, bez refund řádku, bez dopadu na odměnu	<code>HandlePaymentNotification.cs:604-609;</code> <code>rg -n "OrderEmployeePay" src/Cleansia.Core.App Services/Features/Payments/HandlePaymentNotification.cs → 0</code>	společnost	vysoká	chargeback jako pohyb peněz
<code>Refund.StripeRefundId</code> vždy null; id refundu ze Stripe se neukládá	<code>RefundService.cs:170</code>	společnost	střední	uložení <code>StripeRefundId</code>

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Storno u hotovosti zapisuje <code>FeeRate</code> 25/50 % přes <code>order.Cancel</code> ; refund běží jen pro <code>PaymentType.Card</code> ; inkaso poplatku neexistuje	<code>CustomerOrderCancellation.cs:49;</code> <code>CustomerOrderCancellation.cs:90-95</code>	společnost	vysoká	→ R6
Vybraná hotovost se nezapočítává proti odměně: složkami jsou <code>BasePay</code> , <code>ExtrasPay</code> , <code>ExpensesPay</code> , <code>BonusPay</code> , <code>DeductionPay</code> ; lhůta odvodu neexistuje	<code>rg -rn "CashCollected SettledInCash"</code> <code>src/Cleansia.Core.AppServices/Features/EmployeePayroll → 0;</code> <code>OrderEmployeePay.cs:38-46</code>	společnost	vysoká	→ R6
Plus člen plánu <code>PLUS_MONTHLY</code> (<code>freeWindow 4 h</code>) nikdy neplatí 25 %: <code>h >= freeWindow</code> zdarma, jinak <code>LastMinute 50 %</code>	<code>BookingPolicy.cs:345-352;</code> <code>insert_seed_data.sql:1805-1806</code>	zákazník	střední	→ R4
Fiskalizace vypnuta (<code>Fiscal:CzechEet2:Enabled=false</code>); <code>CzechEet2FiscalService</code> je stub, výchozí <code>NoOpFiscalService</code>	<code>appsettings.json:85;</code> <code>CzechEet2FiscalService.cs:8-12</code>	společnost	střední	→ R21
Jedna konfigurace <code>Stripe:SecretKey</code> bez směřování na účet jednotlivé společnosti; vlastnictví Stripe účtu kód nedokládá	<code>StripeClient.cs:34;</code> <code>rg -n "StripeAccount OnBehalfOf TransferData"</code> <code>src/Cleansia.Core.AppServices</code> <code>src/Cleansia.Infra.Clients → 0</code>	společnost	střední	→ R2
Období lze znovu otevřít, není-li <code>Paid</code> ; faktura se generuje bez ohledu na stav období (<code>PayPeriodId</code> jen <code>ExistsAsync</code>)	<code>ReopenPayPeriod.cs:40-44;</code> <code>GenerateInvoice.cs:42-47</code>	úklidník / společnost	střední	brána stavu období

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Úprava částek faktury volá <code>UpdateAmounts</code> a končí — handler drží jediný <code>IEmployeeInvoiceRepo</code> sitory , vydané PDF nese starou částku; přegenerování je samostatný příkaz s <code>LanguageCode</code>	<code>UpdateInvoiceAmounts.cs:57;</code> <code>RegenerateInvoicePdf.cs:59</code>	úklidník	střední	→ R18
Hromadné mzdové sazby (<code>BulkCreateEmployeePayConfigs</code>) výchozí <code>Math.Round (ToEven);</code> výpočet mzdy (decimal součty) bez zaokrouhlení	<code>BulkCreateEmployeePayConfigs.cs:140-141;</code> <code>PayCalculatorExtensions.cs:44-52</code>	úklidník	nízká	jednotné zaokrouhlení
DEV firemní údaje mají IČO <code>12345678</code> a zástupný účet; <code>CompanyFields</code> neplátci DIČ netiskne	<code>insert_seed_data.sql:1</code> <code>161;</code> <code>DefaultReceiptLayoutBuilder.cs:142</code>	zákazník / společnost	střední	→ R2
Swap plánu maže lokální <code>CancelledAt</code> , ale <code>SubscriptionUpdateOptions</code> <code>cancel_at_period_end</code> neruší; předplatné na Stripe dál končí	<code>UserMembership.cs:3</code> <code>02-304;</code> <code>StripeClient.cs:368-</code> <code>379</code>	zákazník	střední	zrušení <code>cancel_at_period_end</code> při swapu
„First-order“ promokód (<code>maxRedemptionsPerUser</code> 1) nekontroluje, zda jde o první objednávku	<code>RequestPromoCodes.cs:84-91</code>	společnost	střední	kontrola první objednávky

3. Data a retence

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Sdílená adresa se při výmazu nahrazuje anonymní kopií; cizí reference vložená před smazáním původního řádku může výmaz odmítnout přes FK	GdprDeletionService.cs:402; OrderEntityConfiguration.cs:38	zákazník	nízká	opakování výmazu při souběhu
Výmaz neodstraní samostatný řádek Address, pokud na něj neodkazuje objednávka ani profil úklidníka	GdprDeletionService.cs:395; GdprDeletionService.cs:416	zákazník	střední	→ R9
GetOwnOrdersByPhoneNumberAsync aktualizuje jen vlastní objednávky; zápis do objednávky zmrazené společnosti může odmítnout CompanyArchivedException	OrderRepository.cs:13; CleansiaDbContext.cs:148	zákazník	střední	→ R9
Retenční sweep anonymizuje jen objednávky s historií Completed; zrušené a nesplněné se neanonymizují nikdy	DataRetentionBackgroundService.cs:180-183	zákazník	střední	sweep i pro zrušené
Fotky dokončených zakázek mají výchozí okno 7 dní; otevřený spor brání sweepu. Výmaz účtu používá odlišný chybný parser blobové cesty	OrderPhotoRepository.cs:39; GdprDeletionService.cs:560	zákazník	střední	→ R7
DeleteOrderPhoto bez [AuditAction] a bez brány na stav zakázky (jen AssignedEmployees.Assign); smaže i fotografii „po“, na níž dokončení stálo	DeleteOrderPhoto.cs:12; DeleteOrderPhoto.cs:56-71	zákazník / společnost	střední	→ R7

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
DefaultAdminAuditRetentionYears i výchozí okno úklidníků jsou 3 roky; rozsah nastavení je 1–100 let (MaxYears). Archiv má samostatnou politiku	RetentionDefaults.cs:30; TenantSettingCatalog.cs:105	úklidník / společnost	nízká	→ R9
AnonymizeCustomerData ponechává CustomerFloor a CustomerApartment	Order.cs:980	zákazník	střední	→ R9
RevokeAsync odvolává tokeny hosta v CancelGuestOrder a při výmazu; ostatní storna nemají společný krok revokace	CancelGuestOrder.cs:61; GdprDeletionService.cs:412	zákazník	střední	→ R5
Receipt worker a fiskální retry mohou vydat token i anonymizované hostovské objednávce; issuer ověřuje jen nepřítomnost účtu	GuestOrderAccessTokenIssuer.cs:31	zákazník	střední	→ R9
Dokumenty úklidníka (PDF a Office) ImageMetadata nescrubuje; administrátor je stahuje (DownloadEmployeeDocument) i s metadaty autora	ImageMetadata.cs:28-31; AdminEmployeeDocumentController.cs:93-99	úklidník	nízká	scrub dokumentů, nebo popis v DPA
Právní texty s bannerem Návrh – toto znění zatím neprošlo právní kontrolou seeduje LegalDocumentSeedHostedService při každém startu v každém prostředí	LegalDocumentSeedHostedService.cs:16-20; cs.md:5	společnost	vysoká	→ R3

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Souhlas úklidníka s podmínkami odkazuje na žádný text (document: null); dokument LegalDocumentAudience.Employee neexistuje	RegisterEmployee.cs:121-126; LegalSeedResource.cs:28	úklidník / společnost	vysoká	→ R3
Admin příkaz na novou verzi právního dokumentu neexistuje; AdminLegalController jen čte (CanViewLegalDocuments)	rg -rn "ICommand<" src/Cleansia.Core.AppServices/Features/Legal → 0; AdminLegalController.cs:21	společnost	střední	→ R3
Tick na objednávce neobnoví odvolaný souhlas: AssertedOrAlreadyConsentedAsync ho přijme, OrderBookingEvidence zaznamená, UserConsents se nepíše	CreateOrder.cs:319-322; CreateOrder.cs:1096-1099	společnost	střední	→ R3
MarketingEmails bez čtenáře v AppServices; marketingový push čte jen Promo	grep -rn "MarketingEmails" src/Cleansia.Core.AppServices → 0; SendSitewidePromoFanoutHandler.cs:104	zákazník	vysoká	→ R9
Fan-out kampaně nefiltruje profil: úklidník s Promo = true dostane zákaznický marketing	SendSitewidePromoFanoutHandler.cs:103-109	úklidník	střední	filtr profilu ve fan-outu
Komentář IStripeConfig tvrdí, že GdprDeletionService maže Stripe Customer; kód volá jen RemoveForUserAsync na lokální id	IStripeConfig.cs:30; GdprDeletionService.cs:543-544	zákazník	střední	→ R9

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
RecordAsync ukládá surové tělo RawBody (fronta SendEmail nese adresu a živý kód) bez retence	DeadLetterStore.cs:20-25; rg -n "DeadLetter" src/Cleansia.Core.App Services/Features/DataRetention/PruneOutbox.cs → 0	zákazník / úklidník	střední	retenční okno DeadLetters
Export zákazníka obsahuje ResolutionNotes administrátora a IPAddress + UserAgent souhlasů	GdprExportService.cs:176; GdprExportService.cs:135-137	společnost	nízká	rozsah exportu

4. Odolnost a provoz

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Dead letters nikdo nečte: DeadLetter v admin kontrolerech 0, repozitář jen RemoveForSubjectAsync	rg -n "DeadLetter" src/Cleansia.Web.* / Controllers → 0; DeadLetterRepository.cs:20	společnost	střední	admin čtenář DeadLetters
Outbox po 10 pokusech (backoff 30 s × 2 ⁿ) označí Failed a dead-letteruje; jediná signalizace LogError	OutboxDrainerService.cs:79-86; OutboxDrainerConfig.cs:14-15	všichni	střední	alert na Failed
Alerty zahrnují HealthCheckStatus, latenci, PostgreSQL a poison fronty s threshold: 0; samostatná pravidla pro outbox Failed a databázové dead letters chybějí	alerts.bicep:139; queueAlerts.bicep:96	společnost	střední	alert na stav outboxu a dead letters
Jediným kanálem poplachu je emailReceivers jedné skupiny; poison fronta hlásí GreaterThan práh 0, tedy každou zprávu	alerts.bicep:66-72; queueAlerts.bicep:93-96	společnost	střední	SMS/pager kanál

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Naplnění PRO: SeedDevelopmentData běží jen pod IsDevelopment a insert_seed_data.sql 1 proti PRO workflow odmítá; katalog admin příkazy má, řádek Tenants zapisovače nemá	CleansiaStartupBase.cs:242; execute-sql.yml:49-58	společnost	vysoká	→ R2
Nepříchod posádky zapisuje jediná cesta: kredit CleanerNoShow píše automatický běh CancelUnfilledOrders; host s prázdným UserId jej nedostane	CancelUnfilledOrders.cs:297-300; CancelUnfilledOrders.cs:276-279	zákazník	střední	→ R15
Jediný region weu → westeurope; prod parametry „AUTHORED, NOT DEPLOYED“	main.bicep:224-227; weu.prod.bicepparam:3	společnost	střední	nasazení PRO
Nenasazená konfigurace PRO určuje 35denní geo- redundantní zálohu a ZoneRedundant; v deploy není postup obnovy	weu.prod.bicepparam:56; weu.prod.bicepparam:58	společnost	střední	postup obnovy
Provozní runbook jen pro DEV (787 řádků); PRO posture 196 řádků bez incident/on-call postupu	AZURE-DEV-RUNBOOK.md:1; rg - in "incident on-call" deploy/AZURE- PROD-POSTURE.md → 0	společnost	střední	→ R10
Jediný poskytovatel bez záložního: SendGrid (e-mail), FCM (push, no-op bez tajemství), Stripe, Mapbox (geokódování)	SendGridClientFactory.cs:16; MapboxGeocodingService.cs:14-16	všichni	střední	záložní poskytovatel e-mailu

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
PeriodReminderBackgr oundService bez dedup razítka (čte GetQueryableIgnoring Tenant , nic nezapisuje); opakovaný běh pošle e-mail znovu	PeriodReminderBackg roundService.cs:49-55	úklidník	střední	razítko odeslání
Odchod úklidníka zákazníkovi oznámení neposílá; administrátorské storno nesděljuje důvod, ale úspěšná vratka registrovanému posílá order.refunded	DropOrder.cs:165; PlatformOrderCancell ation.cs:97	zákazník	vysoká	→ R18
Reklamace oznamuje pouze úspěšnou vratku (OrderRefunded); odmítnutí účtu nemá vlastní zprávu, odebrané zakázky hlásí NotifyCleanerOfRevoc ationAsync	ResolveDispute.cs:118 ; RejectEmployee.cs:16 7	zákazník / úklidník	střední	→ R18
ReportOrderIssue.Han dler nikoho neupozorní (jen IOrderRepository a IOrderAccessService , žádný notifikátor)	ReportOrderIssue.cs:4 2-44	zákazník / společnost	střední	→ R10
E-maily Confirmed/Started/C ompleted (EmailService , typ 6 bez seedu, bez per- locale defaults) jdou anglicky každému jazyku	EmailService.cs:397- 412; grep -n "true, 6, " sql- scripts/insert_seed_da ta.sql → 0	zákazník	střední	lokalizace e-mailů
Produkční Customer Mobile host posílá reset hesla na partner.cleansia.cz	appsettings.Productio n.json:30-31	zákazník	střední	oprava URL

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Vývojová fixtura zakládá administrátora <code>admin@cleansia.local</code> se známým heslem <code>Admin123!</code> ; čte se jen uvnitř <code>IsDevelopment</code>	<code>insert_seed_data.sql:1891;</code> <code>CleansiaStartupBase.cs:223</code>	společnost	nízká	jiné heslo mimo DEV

5. Mobilní aplikace

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Uvolnění místa (<code>DropOrder</code>) i žádost o zástup (<code>RequestCover</code>) server nese na partnerském webovém i mobilním hostu	<code>OrderController.cs:240-271;</code> <code>OrderController.cs:285-317</code>	úklidník	střední	→ R10
Trasy <code>DropOrder</code> a <code>RequestCover</code> nevolá žádná aplikace: partnerský web 0, Android <code>partner-app</code> 0, iOS <code>CleansiaPartner</code> 0; žijí jen v generovaných artefaktech (<code>partner-client.ts</code> , <code>partner-mobile-api.json</code>)	<code>rg -n "dropOrder requestCover DropOrder RequestCover"</code> <code>src/Cleansia.App/apps/cleansia-partner.app</code> <code>src/cleansia_android/partner-app/src/main</code> <code>src/cleansia_ios/CleansiaPartner/Sources</code> → 0; <code>partner-mobile-api.json:6620</code>	úklidník	střední	→ R10
Prázdná nástěnka <code>partner</code> iOS (<code>dash_no_jobs_yet_subtitle</code> , <code>L10n.Dashboard.noJobsYetSubtitle</code>) říká „update your availability“; obrazovka dostupnosti neexistuje	<code>Localizable.xcstrings:3624-3636;</code> <code>DashboardView.swift:323</code>	úklidník	nízká	text bez odkazu na dostupnost
Google Pay (<code>GooglePayConfiguration</code>) v Android <code>PaymentSheet</code> ; Apple Pay na iOS 0	<code>BookingBottomSheet.kt:597-606;</code> <code>rg -n "applePay PKPayment"</code> <code>src/cleansia_ios</code> → 0	zákazník	nízká	Apple Pay v <code>PaymentSheet</code>

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
8 push událostí bez kategorie (<code>GetCategoryFor</code> → null) nelze vypnout: <code>OrderAssigned</code> , <code>ReminderSoon</code> , <code>InvoicePaid</code> , <code>EmployeeWeeklyLimits</code> et ...	<code>NotificationEventCata</code> <code>log.cs:226-251</code>	úklidník	nízká	→ R9
Kategorie <code>NewJobsAvailable</code> vypnutelná, ale žádný partnerský endpoint (<code>UpdateNotificationP</code> <code>references</code>) ji úklidníkovi nenastaví	<code>NotificationEventCata</code> <code>log.cs:247-249</code> ; <code>rg -rn</code> "UpdateNotificationP references" <code>src/Cleansia.Web.Part</code> <code>ner</code> <code>src/Cleansia.Web.Mo</code> <code>bile.Partner</code> → 0	úklidník	nízká	endpoint preferencí pro úklidníka
Bez certificate pinningu, root/jailbreak detekce a biometrie (Android i iOS 0); tokeny v <code>EncryptedSharedPrefe</code> <code>rences</code> (Android), Keychain (iOS)	<code>rg -n</code> "CertificatePinner Sec TrustEvaluate RootBe er Jailbreak Biometric Prompt LAContext" <code>src/cleansia_android</code> <code>src/cleansia_ios</code> → 0; <code>TokenStore.kt:44-54</code>	zákazník / úklidník	nízká	pinning; biometrický zámek
Android posílá souřadnice zařízení na <code>api.mapbox.com</code> s <code>access_token</code> , který je v APK jako <code>MAPBOX_ACCESS_TOKEN</code>	<code>ReverseGeocodingSer</code> <code>vice.kt:28-33</code> ; <code>build.gradle.kts:54-57</code>	zákazník / úklidník	střední	→ R9

6. Web

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Před souhlasem se načítají Google Fonts (<code>fonts.googleapis.co</code> <code>m</code> , <code>fonts.gstatic.com</code>) — IP návštěvníka odchází Googlu	<code>index.html:22-23</code> ; <code>index.html:43-49</code>	zákazník	střední	→ R9

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
Cookie „analytics“ se u přihlášeného mapuje na <code>ConsentType.DataProcessing</code> , „marketing“ na <code>MarketingEmails</code> — cookie klik uděluje/odvolává e-mailový souhlas	<code>consent-sync.service.ts:36-41</code>	zákazník	vysoká	→ R9
Úklidník přihlášený v zákaznickém webu (<code>JwtAudiences.Customer</code> přijímá každý profil) odmítnutím cookies volá <code>withdrawConsent</code> na <code>DataProcessing</code>	<code>consent-sync.service.ts:46-50;</code> <code>TokenService.cs:93</code>	úklidník	vysoká	→ R9
Žádný analytický tag neexistuje; banner (<code>categories</code>) přesto nabízí analytics/marketing/preferences	<code>rg -in "gtag googletagmanager clarity hotjar" src/Cleansia.App/apps/cleansia.app → 0;</code> <code>cleansia-cookie-consent.component.ts:88-109</code>	zákazník	nízká	→ R9
Souhlas anonymního návštěvníka jen v <code>localStorage</code> , bez serverového záznamu	<code>cleansia-cookie-consent.component.ts:167-172</code>	zákazník	nízká	→ R9
Okno rezervace 08:00–20:00 vynucují jen klienti (<code>FIRST_WINDOW_HOUR</code> , Android); server konstanty <code>FirstWindowHour</code> / <code>LastWindowHour</code> nečte	<code>booking-window.models.ts:11;</code> <code>BookingPolicy.cs:43-44</code>	společnost	střední	serverová validace okna
Pokles věrnostního stupně při odebrání bodů je bez oznámení; web pokles připouští	<code>LoyaltyAccount.cs:87;</code> <code>cs.json:1344</code>	zákazník	střední	→ R17

7. Dluh

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
<code>OrderStatus.Pending</code> nemá běžný zapisovač, ale platí pro historická data i API a blokuje výmaz	<code>OrderStatus.cs:13;</code> <code>GdprDeletionService.cs:226</code>	společnost	střední	životní cyklus historických stavů
<code>PaymentStatus.Disputed</code> a <code>RefundStatus.Failed</code> nemají běžný zapisovač; klienti a historická data jejich číselné hodnoty přijímají	<code>PaymentStatus.cs:12;</code> <code>RefundStatus.cs:10</code>	společnost	střední	životní cyklus historických stavů
<code>ContractStatus.Active</code> a <code>Terminated</code> nemají běžný zapisovač; jsou součástí historického kontraktu, čtenáři je rozlišují	<code>ContractStatus.cs:9;</code> <code>PeriodReminderBackgroundService.cs:83</code>	společnost	střední	→ R10
<code>IsFirstTimeCustomer = false</code> natvrdo — <code>OpsWindowMinutesFirstTime</code> 60 min se nikdy neuplatní	<code>CancellationAssessor.cs:32;</code> <code>BookingPolicy.cs:83</code>	zákazník	nízká	→ R4
Operátora trhu nastavuje jen <code>AssignOperator</code> bez produkčního volajícího; <code>OperatorTenantId</code> tak zapisuje pouze seed	<code>grep -rn "AssignOperator(" src --glob "*.cs" → 0</code> mimo testy; <code>CountryConfiguration.cs:189-191</code>	společnost	nízká	→ R2
<code>TravelDistance</code> nemá aplikační zapisovač; kilometrová složka čte jen historickou uloženou hodnotu, jinak nulu	<code>Order.cs:108;</code> <code>PayCalculatorExtensions.cs:15</code>	úklidník	nízká	→ R6
Validátor vyžaduje <code>TrialPeriodDays</code> rovno 0; historické <code>TrialEndsAtUtc</code> řídí nárok na výhody a historii čerpání	<code>CreateMembershipPlan.cs:86;</code> <code>UserMembershipRepository.cs:45</code>	společnost	nízká	trial produkt a kompatibilita historických dat

mezera	doklad	kdo je vystaven	závažnost	dlužné rozhodnutí nebo oprava
i18n bez čtenáře: components.availability 22 klíčů × 5 jazyků; partnerská nápověda popisuje Pending jako „legacy state“	git grep "components.availability" -- src/Cleansia.App -- include=.ts -- include=.html → 0; en.json:1714-1715	společnost	nízká	odstranění klíčů
Mobilní katalogy obsahují chybové klíče bez odpovídajícího serverového řetězce, například error.order.cancellation_window_closed a error_referral_self_referral	rg serverových řetězců v produkčním C# → 0; Localizable.xcstrings:3362; strings.xml:1212	společnost	střední	revize neemitovaných klíčů
Zastaralé komentáře: RecurringBookingTemplate „No UI exists today“ (endpoint Create existuje); CancellationPolicyResolver „no Plus product live“ (plány seedovány)	RecurringBookingTemplate.cs:14-15; CancellationPolicyResolver.cs:10-12	společnost	nízká	oprava komentářů
Komentář ConfirmRecurringOrder připsuje webhooku stav Confirmed; webhook nastavuje Paid, přiřazení posádky řeší jiná cesta	ConfirmRecurringOrder.cs:275; HandlePaymentNotification.cs:309	společnost	střední	oprava komentáře
Název společnosti na 3 místech: Tenants.Name „Cleansia CZ s.r.o.“, CompanyInfo.LegalName „Cleansia s.r.o.“, pátička webu a e-mailů „Cleansia s.r.o.“	insert_seed_data.sql:63-64; insert_seed_data.sql:147-1158	zákazník / společnost	střední	→ R2